

DocsAI Compliance Standard Reference Guide

Regulation and Safeguards Manual

Document Overview:

This manual compiles key articles, rules, and regulations across major compliance standards including the General Data Protection Regulation (GDPR) (Regulation (EU) 2016/679), the Health Insurance Portability and Accountability Act (HIPAA), and SEC Rule 10b-5.

Organizations must enforce these policies to maintain certification and adhere to federal and international laws.

Table of Contents:

Page 2: General Data Protection Regulation (GDPR) - Article 6 and Article 13

Page 3: HIPAA Security Standards - Section 164.308 Administrative Safeguards

Page 4: SEC Compliance - Rule 10b-5 Securities Exchange Act

Page 5: Annexes and ISO 27001 Guidelines

PART I: General Data Protection Regulation (GDPR) - Regulation (EU) 2016/679

Article 6 - Lawfulness of processing:

1. Processing shall be lawful only if and to the extent that at least one of the following applies:
 - (a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;
 - (b) processing is necessary for the performance of a contract to which the data subject is party;
 - (c) processing is necessary for compliance with a legal obligation to which the controller is subject;
 - (d) processing is necessary in order to protect the vital interests of the data subject;
 - (e) processing is necessary for the performance of a task carried out in the public interest.

Article 13 - Information to be provided where personal data are collected:

1. Where personal data relating to a data subject are collected from the data subject, the controller shall, at the time when personal data are obtained, provide the data subject with all of the following information:
 - (a) the identity and the contact details of the controller and, where applicable, of the controller's representative;
 - (b) the contact details of the data protection officer, where applicable;
 - (c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing.

PART II: Health Insurance Portability and Accountability Act (HIPAA)

Section 164.308 - Administrative Safeguards:

1. A covered entity or business associate must, in accordance with Section 164.306, implement administrative safeguards.

2. Implementation specifications:

(a) Security Management Process: Implement policies and procedures to prevent, detect, contain, and correct security violations. This requires conducting an accurate risk analysis of the potential vulnerabilities to the confidentiality, integrity, and availability of e-PHI.

(b) Assigned Security Responsibility: Identify the security official who is responsible for the development and implementation of the policies and procedures.

(c) Workforce Security: Implement procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, and to prevent those workforce members who do not have access from obtaining access.

(d) Information Access Management: Implement policies and procedures for authorizing, establishing, restricting, and regulating access to electronic protected health information.

PART III: Securities and Exchange Commission (SEC) Regulations

Rule 10b-5 - Employment of Manipulative and Deceptive Devices:

It shall be unlawful for any person, directly or indirectly, by the use of any means or instrumentality of interstate commerce, or of the mails or of any facility of any national securities exchange,

- (a) To employ any device, scheme, or artifice to defraud,
 - (b) To make any untrue statement of a material fact or to omit to state a material fact necessary in order to make the statements made, in the light of the circumstances under which they were made, not misleading, or
 - (c) To engage in any act, practice, or course of business which operates or would operate as a fraud or deceit upon any person,
- in connection with the purchase or sale of any security.

PART IV: ISO/IEC 27001 Information Security Standard

Annex A - Reference Control Objectives and Controls:

This Annex contains a list of reference control objectives and controls referenced in Clause 6.1.3 of the standard.

A.5 Information Security Policies:

Control A.5.1: Provide management direction and support for information security in accordance with business requirements and relevant laws.

A.6 Organization of Information Security:

Control A.6.1: Establish a framework to initiate and control the implementation and operation of information security within the organization.

A.8 Asset Management:

Control A.8.1: Identify organizational assets and define appropriate protection responsibilities.